

universidad de león Online

Universidad de León ▪ Máster Universitario en Ciberseguridad

Ingeniería del software seguro en la era de la IA generativa

Diseño y Programación Seguras

Conclusiones

Francisco Javier Rodríguez Lera ▪ Camino Fernández Llamas



Instituto de Investigación e Innovación en Ingeniería

Escuela de Ingenierías

universidad de León

Objetivos de aprendizaje

Al terminar el capítulo, el estudiante será capaz de:

- **Recapitular** la hipótesis rectora y su asimetría deliberada.
- **Fijar** las ideas clave de cada bloque del libro.
- **Comprobar** la cobertura de los objetivos de aprendizaje.
- **Declarar** con honestidad las limitaciones e ideas abiertas.

La hipótesis rectora, a la vista del recorrido

- La IA generativa **reduce ciertos costes de implementación** (escritura, andamiaje, traducción, pruebas) **sin eliminar** los problemas de correctitud, seguridad, mantenimiento, portabilidad y responsabilidad.
- No se ha asumido que la IA mejore ni empeore la seguridad *per se*.
- Lo descrito es un *desplazamiento* del esfuerzo hacia especificación, revisión y validación, más una superficie de ataque nueva en la cadena de herramientas.

La asimetría es deliberada: reconocer una ganancia de productividad no equivale a afirmar una ganancia de seguridad. La herramienta abarata escribir; no adivina la especificación, no decide qué es aceptable y no asume la responsabilidad. Esa responsabilidad sigue siendo humana.

Etiquetado epistémico de cierre

Etiqueta	Qué incluye
Evidencia	Revisión, trazabilidad y verificación de requisitos consolidadas; catálogos de debilidades (CWE) y reglas (CERT); límites estructurales de las técnicas; un contenedor comparte el núcleo
Hipótesis	Que la IA desplace el esfuerzo; que completar la especificación mejore el artefacto; que una metodología ordenada reduzca el riesgo (no medido)
Propuesta docente	La metodología AI-SDLC, sus fases y puertas, las rúbricas, las correcciones y el marco de coste total conceptual

Ninguna afirmación **Hipótesis** se presenta como hecho probado; las **Propuestas docentes** son construcciones pedagógicas, no resultados científicos ni normas.

Ideas clave por bloque (1/2)

Anexo A - Caso transversal. El conversor CSV→PDF/XLSX es un ejemplo docente presentado una sola vez; la conversión no es reversible, la reversibilidad del caso se refiere al proceso, no a los datos.

Cap. 2 - Principios clásicos. KISS, DRY, YAGNI siguen vigentes; una heurística admite excepciones y no es una ley. La IA cambia el modo de aplicarlas, no su validez.

Cap. 3 - Correctitud y seguridad. Ocho nociones de «correcto» no se implican entre sí; pre/postcondiciones e invariantes son el contrato; pasar pruebas no es ser seguro.

Cap. 4 - Vulnerabilidades. Familias por CWE; cada corrección es *contextual*, válida para un modelo de amenaza declarado, nunca universal.

Cap. 5 - Portabilidad. Correcto en un entorno, puede fallar en otro; la portabilidad no se hereda automáticamente y no es sinónimo de seguridad.

Ideas clave por bloque (2/2)

Cap. 6 - Evaluación reproducible. Controlar la tupla, registrar condiciones, métricas como *proxies*. El precio no determina la seguridad.

Cap. 7 - AI Act. El uso de IA no convierte por sí mismo el producto en sistema regulado; lo determinante es la naturaleza del artefacto y su uso previsto.

Cap. 8 - Confianza no calibrada. El código generado es *plausiblemente incorrecto*; el riesgo es epistémico y se mitiga con especificación, independencia de contexto y calibración.

Cap. 9 - Aislamiento y agentes. Riesgo del código $\neq$ riesgo de las acciones; un contenedor ordinario no es, por sí solo, un límite de seguridad.

Cap. 10 - Validación automática. Pipeline con puertas *fail-closed* y trazabilidad; hereda falsos negativos: verde $\neq$ seguro.

Cap. 11 - Verificación. Contratos, invariantes y amenazas convierten requisitos en propiedades comprobables; las diferencias humano-IA se tratan con un protocolo neutral.

Cap. 12 - Metodología AI-SDLC. Diez fases, gobernanza en cinco ámbitos; propuesta docente, no estándar ni certificación.

Trazabilidad objetivos ↔ secciones

- Cada objetivo de aprendizaje del libro se relaciona con las secciones que lo cubren (tabla de **Propuesta docente**, comprobada en la auditoría final).
- Objetivos centrales: distinguir nociones de «correcto»; formular contratos; identificar familias por CWE; explicar por qué las pruebas finitas no demuestran seguridad; diseñar un protocolo reproducible; calibrar la confianza; verificar con contratos e invariantes; distinguir sistema regulado de software convencional; modelar amenazas de agentes; diseñar pipelines; distinguir verificación, aprobación, despliegue y riesgo residual; aplicar el AI-SDLC y reconocer sus límites.
- La trazabilidad conecta objetivos, secciones y prácticas de laboratorio.

Ideas abiertas y limitaciones

1. **Vigencia y alcance del AI Act:** consolidado de 27-07-2026 (incluye 2026/1744); aplicación escalonada por disposición y tipo de sistema, no por una fecha única. No es asesoramiento jurídico.
2. **Verificación de los CWE:** 27 identificadores contrastados con MITRE (2026-10-24); repetir la comprobación si se añaden.
3. **Sin mediciones:** se describen protocolos y marcos; no se presentan resultados, cifras ni comparaciones.
4. **Dependencia de versión y configuración:** capacidades de herramientas **A VERIFICAR**.
5. **Aislamiento no verificado empíricamente:** escenarios defensivos y conceptuales; no se garantiza la suficiencia de una configuración.
6. **Corrección contextual:** ninguna corrección es «universalmente segura».

La verificación de la literatura y la auditoría final del libro quedan como tareas de cierre.

Cautela invariante del libro

- Superar una batería finita de pruebas **no demuestra seguridad**.
- Un ejemplo «corregido» es correcto de forma *contextual*, nunca «universalmente seguro».
- El aislamiento reduce el daño de un artefacto hostil; no certifica que sea seguro ni que sea infranqueable.
- Los ejemplos vulnerables del material son **material didáctico**: solo en entornos aislados y autorizados.

La seguridad es una propiedad que se *argumenta* con evidencia y responsabilidad, no un certificado que se obtiene.

Síntesis final

- La IA *abarata producir* artefactos; no abarata *saber cuánto valen*.
- Los instrumentos de la ingeniería (contratos, invariantes, modelos de amenazas, pruebas, análisis, aislamiento, trazabilidad) siguen siendo los mismos para código humano y generado.
- La responsabilidad epistémica y la aprobación no se delegan en la herramienta.
- El recorrido deja protocolos y marcos para obtener evidencia; no resultados inventados.

Actividad de cierre

1. Elija un objetivo de aprendizaje y trace su cadena: objetivo → sección → práctica → evidencia.
2. Identifique una afirmación etiquetada como **Hipótesis** en el libro y describa qué estudio la contrastaría.
3. Redacte una formulación honesta de aceptación de un artefacto del caso transversal.

¿Qué queda abierto?

- ¿Qué preguntas sobre IA y seguridad del software siguen sin respuesta medida?

Referencias I